

CYBERSECURITY GUIDE

A practical framework for small NGOs in Luxembourg

Version 1.0

University of Luxembourg Project in Cybersecurity Risk Management

BAUDET Antoine

STELMES Noah

NWAOYIBO Chiamaka

DINH VO TRUC Ngan

About this guide

This guide helps small NGOs in Luxembourg protect their data, their work, the people they serve, and to fulfil their regulatory obligations. It is written for organizations with limited budgets and limited (or no) technical staff.

You do not need to be a cybersecurity expert to use it. You need to recognize which of the two tiers describes your NGO and then follow the practical steps for that tier.

Who this guide is for

- Small NGOs in Luxembourg: patient associations, prevention organizations, peer-support groups, small care providers.
- Volunteer-led or small-staff organizations, typically up to twenty people.
- Anyone responsible for protecting the NGO's data and information systems: a director, a board member, an operations manager, an IT volunteer.

Who this guide is not for

- Large NGOs with dedicated security teams.
- Hospitals and other healthcare providers, who fall under sector-specific rules.
- Anyone looking for a formal certification scheme: this is a working framework, not a badge.

A note on language

Wherever a technical term is needed, this guide explains it the first time it appears. If you encounter something unfamiliar, your IT person, an external IT consultant, or NC3 Luxembourg (see Useful Contacts at the end) can help.

The two tiers in one minute

This framework has two tiers. The only question that determines which tier you belong to is: Does your NGO have at least one person who can technically operate cybersecurity controls?

	Tier I	Tier II
Team size	1–5 people	Up to about 15 people
Cyber-capable person	None on the team	At least one (paid, volunteer, or external)
What you can do	Use the security built into your tools	Configure and check your tools properly
Key risk	Full dependency on vendors	If your one IT person leaves, you are stuck

If you are not sure which tier describes your NGO, the section "*Which tier are we?*" At the end of this guide, you will get a clear answer.

The Five Basics every NGO must do

These five practices cost very little and prevent the majority of cyber incidents. They apply to every NGO, in every tier, with no exception.

If any of these five are missing, fix that before doing anything else in this guide.

1. Turn on two-step login (MFA) everywhere

Every account that holds your work, email, cloud drives, banking, online tools, should require both a password and a second step (a code from your phone, a notification in an app).

This is the single most effective protection you can put in place. Most cyber incidents that affect small NGOs start with a stolen password. Two-step login stops almost all of them.

2. Make sure your data is backed up

Use a cloud workspace, Microsoft 365 for Nonprofits or Google Workspace for Nonprofits, both free for eligible NGOs. Once your work lives in the cloud, your files are saved automatically.

Conduct an annual restoration test to ensure backup integrity; identifying and resolving technical issues now prevents catastrophic data loss when a recovery is genuinely required.

3. Let your devices update themselves

Turn on automatic updates on every computer and phone the NGO uses. Most cyberattacks exploit problems that updates have already fixed.

4. Hold a one-hour awareness session, once a year

Cover three things: how to spot a suspicious email, why passwords should not be reused across services, and what to do if something seems wrong.

Free materials are available from NC3 (Luxembourg) and ENISA. Every new joiner does the same session.

5. Keep an emergency contact card

A single page printed and stored offline: not on a system that might itself be down during an incident.

The card lists:

- Who to call first inside the NGO
- CIRCL (Luxembourg's incident response service)
- Police: 113
- Your main cloud provider's support line

Standing rule for the team

If something looks wrong (unexpected emails sent in your name, accounts you cannot log into, files disappearing, ransom messages) disconnect the device from the internet and call the designated person before doing anything else. Never pay a ransom.

Tier I: Less than five people, no IT person

This tier is for the small NGO run by volunteers and program staff where **nobody on the team is comfortable configuring computer systems or cloud services**. You rely on the security built into the tools you use, and on a small number of simple human habits.

What Tier I can realistically do

- Choose tools where security is built in
- Turn on the protective features that already exist
- Build a few simple safety habits
- Know who to call when something goes wrong

What Tier I cannot realistically do (and should not pretend to do)

- Run its own servers
- Monitor security logs
- Conduct security drills

Pretending otherwise creates fake protection -> controls that exist on paper but are never operated.

How to set up Tier I

Choose one cloud workspace

Use Microsoft 365 for Nonprofits or Google Workspace for Nonprofits. Both are free for eligible NGOs. Put all your NGO work there: your email, your shared documents, your calendars.

Do not run your own email server. Do not run a local file server. Do not run anything else technical.

Set it up safely, once

- Turn on **security defaults** (Microsoft) or **2-step verification for everyone** (Google). This forces two-step login across the whole team.
- Give every person their own login. **No shared accounts**.
- Install a **password manager**. Bitwarden is free; 1Password is free for nonprofits. Everyone on the team should use it.

Keep devices simple

- Each person has their own device with a login password, and **automatic updates** should be turned on.
- **Disk encryption** is on. On modern Mac, Windows, and Chromebook devices, this is the default, just check.
- Use the **antivirus** built into the operating system (Microsoft Defender on Windows, the built-in protection on Mac and Chromebook).

Handle email carefully

- Sensitive information goes through **shared drive links**, not through email attachments.
- Train the team: if an email feels wrong, do not click. Forward it to one designated person to check.
- Keep communication open. If an email sounds urgent but suspicious, always verify it came from its acclaimed source.
- During setup, look in your cloud admin help for "*email authentication*" and follow the steps. It is a one-time setup that protects your domain from being faked by attackers.

Back up your data

Because your work lives in the cloud workspace, basic backup is built in. To stay safe:

- Make sure no critical file lives only on someone's laptop. Everything important goes in the shared cloud drive.
- Once a year, ask someone to restore a file from the workspace's recycle bin or version history, just to confirm it works.

That is enough for Tier I. More elaborate backup setups (multiple media, off-site copies) are designed for larger organizations and rarely fit for a five-person NGO.

Prepare for incidents before they happen

Print and store offline a card with the contacts listed under "The Five Basics".

Keep the standing rules visible. If something looks wrong, disconnect the device and call the designated person before doing anything else.

When Tier I is not enough

If your NGO handles patient records, children's data, or other sensitive personal data on more than a small handful of people, Tier I is not enough. You have two options:

- Grow toward Tier II by recruiting or contracting a person who can operate cybersecurity controls.
- Partner with a Tier II organization that handles sensitive data on your behalf, under a formal data-processing agreement.

Tier II: Up to twenty people, with at least one IT person

This tier is for the small NGO with **at least one person**: paid, volunteer, or external contractor: **who can log into admin consoles, manage devices, and check security alerts**. This unlocks a level of protection that Tier I cannot reach.

Tier II is still a small NGO. Typically, up to around 15 people. It is not enterprise security. You are not building a security operations center; you are not pursuing cybersecurity certifications; you do not need a 24/7 monitoring service. Stay proportionate.

Tier II starts with everything in Tier I

All the Tier I controls still apply: the five basics, the cloud workspace, the device basics, the contact card. Tier II builds on top of them; it does not replace them.

How to strengthen Tier II

Strengthen your logins

- Your IT person turns on **conditional access** in the admin console: require two-step login when someone connects from an unusual location and block old login methods that can be hacked.
- Your IT person has **two** separate accounts: one for daily work (email, meetings, files), and one for admin tasks (managing the system). They never browse the web with the admin account.
- Every three months, your IT person reviews who has access to what systems. Anyone who has left the organization must have their access removed immediately. Any staff with broader access than their role requires should have their permissions trimmed down to the level of their role.
- When someone leaves the NGO, a written checklist is followed within 24 hours: disable their account, recover their files, change any shared passwords they knew.

Manage your devices properly

- Use a device management tool: **Microsoft Intune**, **Google MDM**, or **Apple Business Manager**: to enroll every NGO device. This lets your IT person update them, lock them if lost, and check that they meet basic security settings.
- Write one short paragraph on what files or systems personal devices may and may not access. (Most small NGOs allow email and calendar on personal phones but restrict sensitive documents to NGO-managed devices.)
- Maintain a simple list of every device the NGO uses, who has it, and when it was set up.

Make email safer

- Move email authentication from monitoring mode to enforcement (your IT person knows what this means in practice).

- Tune the anti-phishing settings in the admin console. They come pre-configured but can usually be improved with a short review.
- Add a "report this email" button or a designated address inside the NGO for staff to forward suspicious mail.

Treat backups seriously

- Once a year, restore a sample of files from backup. Do not just trust the dashboard saying backup is working, test it.
- Set retention rules: deleted files are kept for a defined period, then permanently removed. Personal data is kept only as long as needed for the purpose it was collected.

Train and prepare

- Document every important step your IT person takes. If they leave tomorrow, the next person should be able to pick up from where they stopped.
- Once a year, sit down with the board and the IT person for a one-hour exercise: "what would we do if all our files were locked by ransomware?" Walk through the steps.
- Store admin passwords of last resort in a sealed envelope or a shared password vault, so the NGO is not locked out of its own systems if the IT person is unreachable.

Check on your suppliers

Before signing with any new tool that processes personal data, ask the supplier five questions:

1. Where is our data hosted? (Inside the EU is preferred.)
2. Are you GDPR compliant? Will you sign a Data Processing Agreement with us?
3. Have you had a data breach in the last two years? How did you handle it?
4. Do you hold any security certifications?
5. If we stop using your service, how do we get our data back?

Review the answers for your existing key suppliers once a year.

Keep a simple risk list

This is the single most useful Tier II practice. Once every three months, sit down with the IT person and review:

- What are the most likely things that could go wrong?
- What would hurt us the most if they happened?
- Are we doing what we said we would about them?
- What has changed since last time? What near-misses happened?

The section "Your risk list" later in this guide includes a template.

Run an annual check-up

Use Fit4Cybersecurity (free, from NC3 Luxembourg) once a year. Get a score. Share it with the board. Aim to improve it gradually.

Additional steps if you handle sensitive personal data

If your NGO processes data on health, vulnerability, children, or other special categories of personal data, add these steps to your Tier II routine. They are additions, not a separate tier.

Formalize your DPO function

You need a Data Protection Officer for the processing of special-category data at any meaningful scale. The DPO can be internal, external on retainer or shared with another NGO. The role must have a job description, dedicated time, and direct access to leadership.

Classify your data

Walk through the systems you use and mark each file or folder with one of four labels:

- **Public:** can be shared freely.
- **Internal:** NGO use only.
- **Personal:** regular personal data (names, contacts).
- **Sensitive personal:** special-category data under GDPR.

Apply stricter rules to "sensitive personal": fewer people have access; it lives in a more controlled system. Sharing it externally requires explicit approval.

Run a DPIA when starting new processing

A **Data Protection Impact Assessment** is a short document of a few pages that walks through: what data, why, who has access, how long you keep it, what could go wrong, what you do about it. The CNPD provides templates. Do this *before* starting a new system or program that involves sensitive personal data.

Maintain your record of processing

Keep an up-to-date list of every way your NGO processes personal data. The list should contain information about what data exactly, for what purpose, what legal basis, who has access, and how long you keep it. Update it as things change. Do not try to reconstruct it once a year.

Have an external pair of eyes occasionally

Every two to three years, ask a security consultant or a trusted external peer to look at your setup and give honest feedback. This serves as an outside perspective; it is not a formal audit.

What Tier II at this scale should NOT do

- No custom security operations center or 24/7 monitoring.
- No cybersecurity certification program.
- No dedicated security-only staff.
- No expensive penetration testing program.
- No bespoke security tools beyond what your cloud platform already provides.

If your NGO genuinely needs those, it has outgrown this framework.

Which tier are we?

Answer one question:

The one question

Does your NGO have at least one person: staff, volunteer, or recurring external contractor: who can log into a cloud admin console, manage device settings, and read security alerts?

No → you are Tier I. Follow the Tier I section.

Yes → you are Tier II. Follow the Tier II section.

If your NGO handles sensitive personal data (health data, data on vulnerable people, children's data) on more than a small number of individuals, also follow the "Additional steps if you handle sensitive personal data" subsection inside Tier II.

If you are Tier I but you handle sensitive personal data

This is a difficult position. The honest options are:

- Work toward Tier II: recruit or contract a person who can operate the controls.
- Partner with a Tier II organization that handles sensitive data on your behalf, under a formal agreement.

Continuing to handle sensitive data without a cyber-capable person on the team is the riskiest configuration of all. Be honest with yourself, your board, and your funders about it.

Your risk list

The risk list is one page. It lives somewhere your leadership team can see it. You update it every three months (Tier II) or once a year (Tier I).

Six columns, three levels, four responses

Each row has six columns:

Column	What goes in it
Risk	A short description (one line)
How likely?	Low / Medium / High
How bad?	Low / Medium / High
What we are doing	The control or action that addresses it
Who is responsible	One name
When to check next	A date (quarterly for Tier II)

For each risk, choose one of four responses:

- **Accept:** the risk is small; the fix would cost more than it is worth. Monitor it.
- **Reduce:** put control in place to make the risk less likely or less serious.
- **Transfer:** someone else handles it (an insurance company, vendor, a partner organization).
- **Avoid:** do not do the activity at all, because the risk is too high.

A starter list of risks for a small NGO

- Someone clicks a phishing email and an account is stolen.
- A laptop is lost or stolen with personal data on it.
- A staff member misdirects an email containing personal information.
- The main shared drive is hit by ransomware.
- The IT person leaves, and the NGO cannot get into its own systems.
- A supplier we depend on has a data breach.
- Someone who left the NGO six months ago still has access to systems.
- A staff member uses a personal email account or device for sensitive NGO work.

The most valuable habit: write down your near misses

Every three months (or every year for Tier I), add a short note about anything that almost went wrong:

- A phishing email that nearly worked.
- A device that was nearly lost.
- An external sharing link that was almost sent to the wrong person.
- A login alert that pointed at an unfamiliar location.

Write down what happened, what stopped it, and what would have prevented it. Share these notes inside the NGO: they are how the team actually learns. This is the single most valuable security practice an NGO can adopt, and the one most often skipped.

Moving from Tier I to Tier II

This usually happens when:

- You hire your first IT person or sign a regular IT contractor.
- A near-miss showed that Tier I is no longer enough.
- A funder requires evidence of stronger controls.
- You start processing more personal data.

What to do first

1. Write down what Tier I have been doing well: and what it has been doing badly. Honest accounting.
2. Enroll every device in your device management tool.
3. Write your incident response plan in full: more than the contact card on a wall.
4. Start your risk list, with around ten lines.
5. Decide whether you also need the sensitive data steps inside Tier II.

Allow three to six months to settle into Tier II properly.

Going backwards

Tier II can fall back to Tier I if the budget contract or the IT person leaves and is not replaced. This is legitimate when honestly handled.

- Document what you are stopping and why.
- Have the board formally accepted the increased residual risk.
- Inform funders if the change affects the commitments you have made.

Quietly letting controls lapse is far worse than openly downgrading. The framework is honest by design.

Common mistakes to avoid

Tier I mistakes

- **"We are too small to be a target."** False. Most cyberattacks are automated and indiscriminate: they do not pick favorites.
- **Using personal email or personal devices for NGO work.** This is the single most common starting point of incidents in small NGOs.
- **Picking tools by price alone.** Check where the data is hosted and what protections the vendor offers: before signing.

Tier II mistakes

- **The IT person becomes irreplaceable.** If only one person knows how anything works, the NGO is one resignation away from a crisis.
- **Setting things up once and never reviewing.** Settings drift, vendors change; people join and leave. Quarterly review is the minimum.
- **Writing a risk list once and forgetting it.** A risk list that is never updated becomes fiction.

The mistake every tier makes

Staying silent about incidents and near-misses. The team does not learn. The next near miss becomes the next real incident. Talk about what almost went wrong, openly, and regularly. This is the cultural shift that matters most.

Useful contacts in Luxembourg

These organizations provide free, NGO-relevant cybersecurity support. Save the contacts in your emergency card before you need them.

NC3: National Cybersecurity Competence Center

- Operates Securitymadein.lu.
- Free awareness materials, training resources, and the Fit4Cybersecurity self-assessment tool.
- Useful for: yearly check-up, free training, and sector advice.
- Contact: Email info@nc3.lu. Phone: +352 274 00 98 601

CIRCL : Computer Incident Response Center Luxembourg

- National incident response service.
- Free help during a cyber incident, plus threat intelligence.
- Useful for: the call you make first when something serious has happened.
- Contact: Email info@circl.lu. Phone: +352 247 88 444

CNPD : Commission nationale pour la protection des données

- Luxembourg's data protection authority.
- You contact them within 72 hours of a data breach involving personal data.
- Useful for: DPO guidance, breach notification, data protection rules.
- Contact: Email: info@cnpd.lu. Phone +352 26 10 60 10

House of Cybersecurity Luxembourg

- Diagnostic services and sector connections.
- SME-oriented but tools and diagnostics translate well to small NGOs.

Luxinnovation : Fit 4 Cybersecurity

- Structured assessment program.
- Useful for: a deeper diagnostic than the free self-assessment, especially when planning a move from Tier I to Tier II.

Peer networks

- Cercle des associations de patients: peer benchmarking for Luxembourg health-NGOs.
- Other sector federations relevant to your activity.
- Useful for: comparing notes with NGOs of similar size, learning what realistic looks like.

Talking to your funders about cybersecurity

Funders increasingly ask about cybersecurity. Some ask for things small NGOs cannot realistically do: full security operations centers, ISO 27001 certification, dedicated cybersecurity staff.

A well-sustained Tier II is more credible than a Tier II upper end you cannot maintain. Be honest about what your NGO does. Show your funders this guide and the tier that describes you. Most funders prefer a realistic picture to an aspirational one.

Practical asks you can make of your funders

- **Budget flexibility:** allow you to move money between lines if a cybersecurity control needs to change mid-grant.
- **Multi-year cybersecurity funding:** security postures are not built in twelve months. A three-year horizon makes real progress possible.
- **Acceptance of shared or external DPO arrangements:** a twenty-person NGO cannot afford a full-time DPO. A fractional or shared arrangement is the realistic answer.
- **Capacity-building budget, not just compliance demands:** funding for training and tooling matters more than funding to obtain a certificate.

Sharing cybersecurity responsibility fairly

The fairest way to share cybersecurity responsibility is to assign each risk to the party best able to manage it.

- Funders who run shared platforms or systems should secure those systems themselves, rather than pushing the work down to each grantee.
- Grantees should be honest about what they can and cannot sustain.
- Sub-grantees and local partners should not be asked to meet controls without the funding and capacity-building support to operate them.

If you raise this with a funder, do it constructively: point at the risk, name what each party is best placed to handle, and propose a sharing that fits both sides. Most funders respond well to that framing.

Final note

This guide does not eliminate cyber risk. No guide does.

What it does is help you put in place the practices most likely to protect your NGO, sized to what you can realistically sustain.

Start with the five basics. Confirm your tier. Work through the relevant section. Set a date to review your risk list in three months.

That is enough. You are managing cybersecurity.

Disclaimer

This guide is a working framework, not legal advice. For binding interpretation of GDPR, the ASBL law, the ASFT law, NIS2, or sector-specific requirements, consult a lawyer or the relevant Luxembourg authority. Cybersecurity practices evolve: review this guide annually and update your tier and your risk list accordingly.